115 年度 2 月份新人心得報告

資通所人工智慧組 龔修穎

ISO 42001 人工智慧管理系統（AIMS）實務應用與法規查詢智慧助理合規性評估深度研究報告

人工智慧管理系統之背景與組織環境分析

在全球數位轉型與生成式人工智慧（Generative AI）技術爆發的背景下，組織面臨的挑戰已從單純的技術導入，轉向如何建立一個可信賴、安全且符合倫理的技術治理架構。ISO/IEC 42001:2023 作為全球首個針對人工智慧管理系統（Artificial Intelligence Management System, AIMS）制定的國際標準，為組織提供了一個系統化的框架，用以管理 AI 系統全生命週期中的風險與機會 [1]。根據標準條款四（Context of the Organization）的要求，組織必須首先識別與 AI 治理相關的內部與外部因素，並明確利害關係人的需求與期望 [3]。

在本研究報告所涉及的專案中，「陸海空軍懲罰法及軍人權益處理法智慧助理」（系統編號：SYS-001）代表了組織將 AI 技術應用於高度專業且具備法律敏感性領域的嘗試 [5]。由於法律諮詢涉及個人權利與行政決策的正確性，該系統的開發必須嚴格遵循 AIMS 的治理原則。分析指出，組織在推動此類 AI 專案時，其內部環境受限於現有的 IT 治理流程與資料隱私要求，而外部環境則受到如歐盟人工智慧法案（EU AI Act）等新興法規的深遠影響 [7]。

AIMS 的核心價值在於將 AI 系統視為動態發展的資產，而非靜態的軟體產品。這種思維的轉變促使組織必須建立一套持續性的監控與改善機制。在實務操作中，這體現為從「抽象的合規規範」推進至「具象的表單實作」，透過如 AIMS-F12（AI 資產總表）與 AIMS-F05（AI 風險評估表）等工具，將治理要求嵌入到第一線的開發流程中 [5]。

AI 資產盤點之系統化架構與分類邏輯

在 ISO 42001 的框架下，資產盤點是風險管理的起點。不同於傳統資產管理，AI 資產盤點必須涵蓋模型權重、訓練資料集、運算環境以及支撐系統運行的專業人才 [1]。根據 AIMS-P10 AI 資產管理程序書，盤點工作的核心在於建立透明的供應鏈與資產關聯性（Asset Lineage。

AI 資產分類體系分析

根據 AIMS-F12-00 填寫說明，組織將 AI 資產劃分為七大類別，每一類別皆有其特定的管理重點與合規要求。下表詳細列出了這些類別及其在法規助理專案中的具體對應：

資產類型	範例與管理重點	在 **SYS-001** 專案中之應用
資料類	原始資料、特徵資料、向量索引；需關注資料來源合法性與個人隱私。	AS-002 (全國法規資料庫)、AS-003 (法規知識庫向量索引) 。
模型類	模型權重、推論引擎、微調成果；需確保完整性，防止權重遭惡意竄改。	AS-001 (Legal_LLM_Base)、AS-004 (Embedding Model) 。
程式類	訓練/推論程式、MLOps Pipeline、使用者介面；確保 CI/CD 過程安全。	AS-005 (Open WebUI 使用者介面) 。
環境類	GPU 叢集、雲端節點、容器映像；包含 API 金鑰與 Token 管理。	AS-007 (NVIDIA GPU)、AS-008 (Docker 容器平台) 。
測評治理	AI-SBOM、EIA 報告、系統卡；提供透明度與問責性的關鍵證據。	AS-006 (AI-SBOM) 。
外部供應	第三方 LLM API、外部資料供應；檢核供應商合規性。	N/A (本專案目前採內部環境部署) 。
人員類	技術專家、倫理審查委員、HITL 人員；需核查專業勝任能力。	MLOps 維運工程師 [5]。

[5]

系統資源清冊與價值鑑定

針對專案 SYS-001，系統目前處於「G4 上線前審查」階段 [5]。在此階段，資產價值鑑定是決定管理強度的關鍵。根據 AIMS-F12-04 價值與風險判定矩陣，資產價值係由「營運衝擊」、「利害關係人衝擊」與「重建難度」三個維度中的最高分（MAX）決定 [5]。

對於法規助理系統，分析其營運衝擊等級為 1（僅涉及內部行政輔助），利害關係人衝擊度為 2（影響內部人員決策建議，具人工介入機制），重建難度為 1（使用開源模型調整而成）[5]。因此，系統綜合價值等級被判定為 2（中），對應「標準防護」強度 [5]。標準防護要求落實最小權限原則、每半年進

行權限覆核，並依照常規排程辦理備份與傳輸加密 [5]。

值得注意的是，雖然系統整體價值為 2，但部分關鍵資產如 AS-007（NVIDIA GPU）與 AS-006（AI-SBOM）的單項價值被評定為 3 [5]。這反映出硬體運算資源的稀缺性以及合規文件在稽核過程中的重要性，缺失這些資產將導致專案停擺或面臨重大稽核缺失 [5]。

AI 軟體材料清單（AI-SBOM）之合規實務

隨著 AI 供應鏈攻擊頻率增加，建立 AI-SBOM 已成為 ISO 42001 下透明度與安全性管理的核心手段 。AI-SBOM 不僅記錄了軟體套件的相依性，更延伸至模型來源、授權條款以及弱點狀態的持續監控 [5]。

相依元件與授權風險分析

在 SYS-001 專案中，透過 AIMS-F12-03 表單盤點出四個核心相依元件，並追蹤其弱點狀態 。下表彙整了目前的 SBOM 現況：

SBOM ID	元件名稱	版本	供應商	授權條款	弱點狀態 **(2026-03-02)**
SB-001	transformers	N/A	Hugging Face	Apache-2.0	無已知弱點
SB-002	Langchain	1.2.10	Langchain	MIT	無已知弱點
SB-003	transformers	N/A	Hugging Face	cc-by-nc-4.0	無已知弱點
SB-004	Open WebUI	v0.7.2	Open WebUI	MIT	無已知弱點

分析指出，SB-003 所關聯的 Embedding Model 使用了 cc-by-nc-4.0（署名-非商業性使用）授權條款 [5]。在公務系統環境中，此類條款的解釋存在灰色地帶。若系統未來涉及營利性質的衍生應用，可能產生法律爭議。因此，風險評估表（R-2026-003）已將其標記為低度風險，並要求法務窗口進行最終確認 [5]。這體現了 ISO 42001 條款 7.4（Communication & transparency）的精神，即組織必須清楚揭露 AI 模型的使用限制與潛在法律風險。

弱點管理與持續監測機制

ISO 42001 附錄 A 控管要求組織必須落實弱點掃描與修補流程。對於 AS-005（Open WebUI），雖然目前的 SBOM 顯示無已知弱點，但在風險評估中已識別出 R-2026-004，即未來可能出現針對生成式 AI 介面的指令注入（Prompt Injection）攻擊 。

組織採取的控制措施包括：

1. 自動化轉錄：SBOM 內容應由第三方元件掃描工具產出的結論自動彙整，而非手動填寫 。
2. 狀態同步：SBOM 中的「當前弱點狀態」必須與風險處置單（F06-09）保持一致。若風險被決議為「接受」，則 SBOM 狀態應顯示為「殘餘風險監控中」。
3. 隔離防護：針對容器環境（AS-008），實施 Rootless mode 以限制容器權限，並新增針對特定 CVE 的 WAF 攔截規則 。

AI 風險評估架構與量化判定矩陣

ISO 42001 採用基於風險的方法（Risk-based approach），要求組織針對偏見、安全性、透明度、可靠性及生命週期問題進行全面評估 。風險值的計算採「可能性（L）× 影響度（I）」，其分值對應不同的管理層級與處置行動 。

風險判定標準與分級行動

根據 AIMS-F05-00 風險判定矩陣，風險評分尺標分為 1 至 5 分。對於影響度（Impact）的評分，特別強調了對「人權或公共利益」的影響，這與歐盟 AI 法案對高風險 AI 系統的定義高度一致 。下表呈現了風險值的對應處置邏輯：

風險值 **(R)**	風險等級	行動要求
20~25	極高	提報主委裁示，啟動或更新 AI 倫理影響評估（EIA）[5]。
13~19	高	由副主委（管理代表）核准，優先改善，必要時降載或下線[5]。
7~12	中	制定處置計畫並限期追蹤[5]。
1~6	低	例行監控[5]。

[5]

法規助理專案之風險識別清冊分析

針對 SYS-001 專案，目前共辨識出八項關鍵風險，涵蓋了機器學習特性風險、系統生命週期風險及技術成熟度風險 。

1. 幻覺風險 **(R-2026-001)**：模型在回答複雜法律問題時產生幻覺，引用錯誤法條。風險值 9（可能性 3 × 影響度 3），等級為中 [5]。這是法規查詢助理最核心的業務風險。
2. 資料時效風險 **(R-2026-002)**：法規更新但向量索引未同步，導致回答錯誤。風險值 6，等級為低 [5]。此風險主要可透過自動化 ETL 排程解決。
3. 容器逃逸風險 **(R-2026-007)**：Docker 環境配置不當，攻擊者竊取模型權重。風險值 9，等級為中 [5]。此風險威脅資產的機密性與完整性。
4. 人為疏失風險 **(R-2026-008)**：維運人員誤刪部署環境。風險值 9，等級為中 。這反映了在 MLOps 流程中，人員教育培訓與 SOP 建立的必要性 。

模型幻覺與精準度優化之技術決策研究

在法規助理專案中，解決「模型幻覺」不僅是提升用戶體驗，更是滿足 ISO 42001 關於「透明度、解釋性與準確性」之合規要求（Annex A.7 與 A.8）。模型幻覺在法律情境下尤為危險，因為法律條文的微小差異可能導致行政處分的巨大偏差 。

方案 A：深化 AgenticRAG 架構

AgenticRAG 是一種進化版的檢索增強生成架構，其核心在於透過「多智能體協作」與「多步推理」來強化資訊檢索的精確度與事實對齊 。

- 技術機制：系統不再是一次性檢索，而是由一個代理（Agent）判斷查詢意圖，拆解問題，並反覆在向量資料庫（Vector DB）中檢索，最後透過查核模組（Grounding Check）比對生成的回答內容是否完全依附於檢索到的法條原文 。
- 合規優勢：
  1. 可稽核性 **(Auditability)**：每一個回答都能附帶精確的法條來源引用，滿足 ISO 42001 對於 AI 決策透明度的要求 。
  2. 資料即時性：當法規修正時，僅需更新資料庫索引，不需重新訓練模型，降低了「資料時效風險（R-2026-002）」的處理成本 。
  3. 隱私控管：敏感資料存放在受控的向量資料庫中，可透過角色存取控制（RBAC）實現細粒度的權限管理，而非內化在模型權重中，符合遺忘權等隱私規範 。
- 缺陷與挑戰：複雜的推理鏈會增加推論延遲（Latency），且系統的效能高度依賴於文件切分（Chunking）的品質。若法律條文被切割在不同區塊，模型可能無法理解跨條文的關聯性 。

方案 B：特定法規領域微調（Fine-tuning）

微調是透過監督式學習（Supervised Fine-tuning）讓模型在特定領域的語料庫上進行深度調優 。

- 技術機制：將大量的法律文書、裁判書及法條釋義轉化為指令資料集（Instruction dataset），更新模型的參數權重，使模型具備法律專家的語感與先驗知識 。
- 優點：模型的回答會更符合法律專業風格，語氣流暢且具備深度。在特定封閉域的任務中，

微調後的模型通常比一般 RAG 系統有更好的穩定性與較低的推論延遲 。

- 潛在風險與合規困境：
  1. 知識凍結：法律具有時效性，一旦法規修訂，模型必須重新訓練，否則會自信地給出過時的建議 。
  2. 災難性遺忘 **(Catastrophic Forgetting)**：過度微調可能導致模型喪失原有的邏輯推理或通用語言能力 。
  3. 資料纏繞：訓練資料被編碼進參數中，難以選擇性刪除，這在面對 GDPR 或隱私訴訟時會產生嚴重的合規挑戰 。

決策分析與建議

基於法規查詢助理專案的高事實性要求與法規頻繁變動的特性，**AgenticRAG**（方案 **A**）被判定為較優的初始解決方案 。實務上，組織可採取「混合架構」：使用微調來教導模型法律專業的語氣、格式與思考模式，並利用 RAG 來提供最新的事實性資料 。這種方式能同時發揮微調的「行為控制」與 RAG 的「知識更新」優點。

關鍵風險指標（KRI）與監測體系之建立

ISO 42001 條款九（Performance Evaluation）要求組織必須定期監視、測量、分析及評價 AIMS 的表現。這不僅是技術監控，更是治理有效性的驗證。在法規助理專案中，組織透過 AIMS-F05-02 風險登錄清單定義了關鍵風險指標（KRI）與門檻值 。

核心風險監測框架

下表彙整了 SYS-001 系統關鍵風險的監測計畫：

風險 **ID**	風險摘要	關鍵風險指標 **(KRI)**	門檻值	監測機制
R-2026-001	幻覺/引用錯誤法條	使用者回報錯誤件數；隨機抽測準確率	> 3 件/月；< 90%	人工抽測 (HITL) 與回饋蒐集。
R-2026-002	資料時效不同步	資料更新延遲時間	> 24 小時	自動化日誌監控與 Hash 比對。
R-2026-004	WebUI 漏洞暴露	高風險弱點未修補天數	> 3 天	SBOM 定期掃描與 CVE 通報。

R-2026-006	資源不足/服務中斷	系統可用率 (Uptime %)	< 90%	伺服器監控與負載均衡警報。
R-2026-007	容器逃逸/越權存取	高/極高風險漏洞數量	> 0 件	映像檔動態掃描與存取日誌稽核。

這些監測指標的建立，讓 AI 治理從靜態的文件審查轉化為動態的營運流程。例如，當「抽測準確率」低於 90% 時，系統應用組必須啟動根本原因分析（Root Cause Analysis），評估是否為檢索模組失效、Chunking 策略不當或是底層模型發生漂移。

AI 系統全生命週期治理與 G4 上線審查實務

ISO 42001 強調 AI 系統的全生命週期管理（Clause 8.1），確保安全性與倫理考量貫穿從規劃到汰除的每一階段。組織將生命週期分為 G0 至 G7 階段，目前 SYS-001 專案正處於 **G4** 上線前審查的關鍵節點。

生命週期階段管理重點分析

下表定義了各階段的核心合規動作：

階段	名稱	合規重點 (對應 ISO 42001 要求)
G0	開案/需求	確定系統用途、利害關係人與適用法律框架。
G1	資料治理	確認訓練/測試資料的代表性、合法性與去識別化。
G2	開發就緒	完成初步風險評估與 SBOM 初始盤點。
G3	驗證確認	執行魯棒性、公平性與精準度測試，產出測試報告 。
G4	上線前審查	資產價值判定、風險處理計畫核准、EIA 審查結論確認 。

G5	部署/監控	啟動 KRI 監測指標，建立事件應變流程與日誌保留機制。
G6	再訓練	針對重大變更或模型漂移執行風險再評鑑。
G7	汰除	完成資料與模型處置紀錄，確保留存證據並銷毀機敏資訊。

1

G4 階段審核之必要證據與決策邏輯

在 G4 審查中，副主委（管理代表）與主委（最高管理階層）必須針對專案的「風險承受能力」做出最終判斷。對於法規助理系統，審查委員會關注的核心在於：

1. 剩餘風險等級：幻覺風險（R-2026-001）在導入 Grounding Check 與 HITL 之後，其殘餘風險是否已降至「低」且可被接受。
2. 管理強度一致性：系統價值等級為 2，其權限覆核、加密與備份措施是否符合 AIMS-P10 規範。
3. 測評治理資產之完整性：AS-006（AI-SBOM）是否已更新至最新掃描日期（2026-03-02），且所有組件均無致命弱點。

分析指出，若系統未通過 G4 審查，將面臨「預防性降載」或「暫緩部署」的決策。這種制度化的決策流程防止了「影子 AI」（Shadow AI）的出現，確保每一項上線的 AI 服務都在組織的監控與治理範圍內。

管理實務體會與二月份工作績效總結

透過二月份對 ISO 42001 框架的研讀與 SYS-001 專案的實際填報，我深刻體認到 AI 治理並非阻礙創新的絆腳石，而是確保技術能夠永續運行的「護欄」。

AIMS 框架之實務洞察

1. 從「代碼思維」轉向「系統思維」：傳統工程開發注重 Functional Requirements，但 AIMS 要求開發者關注 Non-functional 的生命週期風險。例如，在盤點 Docker 容器時，不能僅看其是否能運行，更要考量其 Base Image 的弱點與「容器逃逸」對整體環境的威脅。
2. 量化管理的必要性：透過 F12-04 的價值判定與 F05 的風險評分，將抽象的「擔憂」轉化為具體的數字。這有助於團隊在有限的算力（GPU 資源）與人力資源下，精準地將防護重點配置於高影響度的環節。
3. 透明度是信任的基石：AI-SBOM 的建立雖然增加了文書工作，但它為系統提供了一份「成分表」。當未來發生類似 Open WebUI 之類的零日漏洞攻擊時，組織能透過 SBOM 快速定位受影響的系統，大幅縮短事件應變時間。

專案進度與下階段里程碑

目前法規助理專案已成功完成 G4 階段前的大部分資產盤點與風險識別工作。二月份的主要績效指標達成如下：

- 資產盤點完成度：100% 完成 SYS-001 所屬九項 AI 資產的 ID 編碼、價值判定與擁有者界定。
- **SBOM** 掃描達成率：已產出 2026-03-02 版本之 AI-SBOM，確認四大相依套件之授權合規性。
- 風險識別深度：針對 AgenticRAG 特性識別出幻覺、資料時效及模型部署等八項關鍵風險，並完成初步緩解計畫之擬定。

總結與未來行動計畫

二月份的學習與實務工作，成功將組織的 AIMS 合規方針轉化為第一線的技術管理實務。透過 ISO 42001 的實踐，法規助理專案不僅具備了先進的技術架構（AgenticRAG），更具備了扎實的合規底蘊與風險控管雛形。

三月份的工作重點將聚焦於以下三個領域：

1. 決策落實：於三月中旬前測階段前，完成方案 A（AgenticRAG 深化）的性能與合規性驗證，特別是 Grounding Check 對 R-2026-001 風險的緩解效果。
2. 績效監測啟動：正式啟動 KRI 監測儀表板，開始蒐集使用者對回答準確度的反饋，作為後續模型調整的依據。
3. 治理流程精進：持續完善 F05-02 的風險追蹤紀錄，確保每一項「進行中」的改善措施（如 WAF 規則新增、自動化 ETL 排程）能如期完成，並為 G5 部署階段做好準備。

在全球 AI 監管趨嚴的環境下，秉持「以風險為導向」的管理精神，將能確保組織在享受 AI 技術帶來的行政效率提升時，同時守住法律合規與社會倫理的底線。